

MODULE 2.2: HACKERS & CYBER CRIMES

Contents

1. Vulnerabilities in Cybersecurity	1
2. Virus.....	2
3. Worms, Trojans, Ransomware, Spyware, and Backdoors	3

Vulnerabilities in Cybersecurity

Vulnerability is a weakness or flaw in a system, network, application, or process that can be exploited by a cyber attacker to gain unauthorized access, steal information, disrupt operations, or damage assets.

- Vulnerabilities are present in hardware, software, networks, or human practices.
- They are the entry points for cyber-attacks.

Types of Vulnerabilities

1. Software Vulnerabilities

- Bugs, coding errors, or misconfigurations in applications or operating systems.
- Examples: Outdated software, unpatched security flaws, buffer overflows, SQL injection vulnerabilities.

2. Hardware Vulnerabilities

- Weaknesses in devices that attackers can exploit.
- Examples: Unsecured ports, firmware flaws, outdated drivers, side-channel attacks.

3. Network Vulnerabilities

- Weaknesses in the design, configuration, or protection of networks.
- Examples: Open ports, weak Wi-Fi security (WEP/WPA), unencrypted traffic, poorly configured firewalls.

4. Human / Social Vulnerabilities

- Weaknesses arising from human behavior or lack of training.
- Examples: Weak passwords, phishing susceptibility, insider threats, lack of awareness about social engineering attacks.

5. Policy and Process Vulnerabilities

- Weak or absent policies, guidelines, or procedures that create security gaps.
- Examples: Inadequate access control, poor patch management, missing incident response plan.

Sources of Vulnerabilities

- **Design Errors:** Flaws introduced during system or software design.
- **Implementation Errors:** Mistakes made while writing or deploying code.
- **Configuration Errors:** Incorrect system or network configurations.
- **Operational Weaknesses:** Poor maintenance, lack of monitoring, or weak procedures.
- **Human Limitations:** Lack of training, negligence, or malicious insiders.

Impact of Vulnerabilities

- Unauthorized access to sensitive data (Confidentiality breach).
- Modification or destruction of critical data (Integrity compromise).
- Service disruption or downtime (Availability compromise).
- Facilitation of advanced attacks like malware, spoofing, or privilege escalation.

Management of Vulnerabilities

- **Regular Patching:** Update software and firmware to fix known flaws.
- **System Hardening:** Reduce unnecessary services, secure configurations, strong passwords.
- **User Training:** Educate staff on phishing, social engineering, and security best practices.
- **Vulnerability Assessment & Penetration Testing:** Identify and test weak points in systems or networks.
- **Monitoring & Logging:** Detect suspicious activity early to prevent exploitation.

Virus

- **Definition:** A program or piece of code that attaches itself to legitimate files/programs and executes when the host is run, thereby infecting other files or systems.
- **Propagation / How it works:** Requires **user action** to run the infected host (open a file, run an executable). Once active, it can modify other files, attach to new executables, or alter boot sectors.
- **Payload / Impact:** Can corrupt or delete files, alter program behavior, log keystrokes, or create backdoors. Often used to damage integrity of data.
- **Examples:** Early file infectors, boot-sector viruses; conceptually similar components appeared in modern attacks (no code examples).
- **Detection & Prevention:** Use up-to-date antivirus/endpoint protection, avoid running unknown executables, enable OS protections (UAC), keep backups, practice safe email/file handling.

Phases of a Virus Program

1. **Design / Creation** — attacker writes the virus code and chooses target behavior.
2. **Triggering / Activation** — condition that makes the payload run (date, user action, file execution).
3. **Execution / Payload** — the malicious action runs (corrupt, encrypt, open backdoor).
4. **Propagation** — virus spreads to other files/systems (email attachments, removable media, network shares).

How to Handle

- **Prevent:** keep systems patched, use AV/EDR, disable autorun, enforce least privilege, train users.
- **Detect:** use signature + behavior detection, monitor logs and unusual outbound traffic.
- **Respond:** isolate infected hosts, preserve evidence, remove persistence, restore from clean backups.
- **Recover:** re-image if needed, rotate credentials, patch exploited flaws, update IR playbook.

Different Generations

1. **1st Gen — Simple viruses:** basic file/boot infectors; easy signature detection.
2. **2nd Gen — Stealth viruses:** hide via hooking/OS tricks from antiviruses; need heuristics/integrity checks.
3. **3rd Gen — Polymorphic viruses:** changes identity or signature every-time it is executed.
4. **4th Gen — Metamorphic viruses:** rewrite their code each generation — very hard for signature scanners. changes identity and rewrites itself
5. **5th Gen — Multi-stage / APT-style malware:** modular, targeted, combines stealth, persistence, lateral movement.

Categories of Viruses

1. **File-Infecter Viruses** — Attach to executable files (.exe, .dll) and run when the program executes; spread by copying infected executables.
2. **Boot-Sector / Master Boot Record (MBR) Viruses** — Infect boot records; activate at system boot and can render systems unbootable.
3. **Macro Viruses** — Embed in document macros (Word, Excel); spread via shared documents and templates.
4. **Resident Viruses** — Install in memory and intercept OS calls to infect other files or hide activity.
5. **Non-resident Viruses** — Perform immediate infection routines and then exit; don't remain resident.
6. **Logic Bombs / Time Bombs** — Triggered by conditions (date, event); may be embedded in legitimate programs.
7. **Backdoor / RAT (when delivered via virus)** — Grants persistent remote control; often combined with trojans.

Worms, Trojans, Ransomware, Spyware, and Backdoors

1. Worm

- **Definition:** A self-replicating malware that spreads across networks without needing a host program or user action (after initial compromise).
- **Propagation / How it works:** Exploits network vulnerabilities, open ports, or weak authentication to copy itself to other machines; often incorporates payload delivery and propagation routines.
- **Payload / Impact:** Can consume network bandwidth, cause massive system outages, drop secondary payloads (ransomware/backdoors), or corrupt systems — high availability impact.
- **Examples:** Classic worms (e.g., Morris worm concept), and modern worm-like outbreaks that propagated via vulnerabilities (e.g., WannaCry used EternalBlue to spread).
- **Detection & Prevention:** Network-level IDS/IPS, firewall rules, patch management to fix exploited vulnerabilities, network segmentation, rate-limiting and anomaly detection.

2. Trojan (Trojan Horse)

- **Definition:** Malware that masquerades as legitimate software or hides inside legitimate software to trick users into installing it; it does not self-replicate.
- **Propagation / How it works:** Delivered through social engineering, fake installers, cracked software, email attachments, or bundled with downloads. Once executed, it performs hidden malicious actions.

- **Payload / Impact:** Can open backdoors, install remote access tools (RATs), steal credentials, download additional malware, or turn a host into a bot. High confidentiality and integrity risks.
- **Examples:** Banking Trojans (steal credentials), Remote Access Trojans used for espionage.
- **Detection & Prevention:** Verify software sources, code-signature checks, endpoint protection that detects suspicious behavior, application whitelisting, user awareness.

3. Ransomware

- **Definition:** Malware that encrypts a victim's files or systems (or otherwise denies access) and demands payment (ransom) for the decryption key or restoration.
- **Propagation / How it works:** Delivered via phishing, trojans, or worms; sometimes uses exploits to spread laterally. Once inside, it encrypts files, modifies backups, and may exfiltrate data for double extortion.
- **Payload / Impact:** Loss of access to critical data, business disruption, financial loss (ransom + recovery costs), reputational damage, potential data leak if exfiltrated.
- **Examples:** Notorious families/events have included LockBit, Conti, and WannaCry (WannaCry combined worm behavior and ransomware).
- **Detection & Prevention:** Frequent offline and immutable backups, least-privilege access, network segmentation, EDR/endpoint detection, MFA, patching, user training to resist phishing, rapid incident response plans.

4. Spyware

- **Definition:** Software that secretly monitors user activity and collects sensitive information (keystrokes, browsing habits, credentials) without consent.
- **Propagation / How it works:** Bundled with downloads, installed by malicious pages, delivered by trojans, or installed by insiders. Some types are persistent and hard to remove.
- **Payload / Impact:** Theft of credentials, privacy invasion, targeted surveillance, data leakage. Often used for espionage or targeted account takeover.
- **Examples:** Keyloggers, tracking cookies in malicious software bundles, commercial spyware used for surveillance.
- **Detection & Prevention:** Anti-spyware/antivirus, minimal privileged installs, browser hardening, avoid dubious downloads and extensions, monitor outgoing connections and data exfiltration patterns.

5. Backdoors

- **Definition:** Hidden access methods (software or accounts) that allow attackers to bypass normal authentication and re-enter a system at will.
- **Propagation / How it works:** Installed by trojans, left by attackers after exploitation, created via hardcoded credentials, or built into compromised firmware/software. Backdoors can be persistent and stealthy.
- **Payload / Impact:** Persistent unauthorized access, remote control, data exfiltration, ability to launch further attacks (install additional malware, pivot inside the network).
- **Examples:** Hidden admin accounts, malware that opens a listening service, webshells on compromised web servers.
- **Detection & Prevention:** Integrity checks, regular account audits, firmware and software patching, host-based EDR to spot unusual services or connections, remove unexpected admin accounts, limit privileged accounts, periodic full-system audits.

Cross-cutting Notes (Useful for exams)

- **Overlap:** Many real-world attacks combine these types (e.g., a trojan installs a backdoor and downloads ransomware; a worm carries a trojan payload).
- **CIA impact:**
 - Viruses/Trojans/Backdoors → mainly **confidentiality & integrity** issues (and persistence).
 - Worms & ransomware → heavy **availability** impact (outages) plus confidentiality when data exfiltrated.
 - Spyware → primarily **confidentiality** loss.
- **Defence strategy pillars:** Patch management, endpoint protection (AV/EDR), network defenses (IDS/IPS, segmentation), strong authentication (MFA), backups (offline/immutable), least privilege, user training, and incident response.
- **Detection methods:** Signature-based detection (AV), behavior-based detection (EDR), network anomaly detection, sandboxing suspicious files, and threat hunting.